

Estado actual de seguridad

facturacion-autonomos.app

Medidas vigentes, cobertura y riesgos residuales.

ESTADO VIGENTE

Comprobación técnica: 17 de julio de 2026

CSP en bloqueo

Cabeceras estrictas y CORS limitado.

RLS por usuario

Aislamiento de filas y grants mínimos.

Copias cifradas

AES-256-GCM antes de descargar o usar Drive.

Abuso observable

Rate limit distribuido y avisos en Admin.

Documento canónico del estado actual. No contiene credenciales, tokens, IP, documentos de clientes ni datos personales. No sustituye una auditoría ofensiva independiente.

Alcance del informe

Este informe reúne las medidas de seguridad visibles en código, Supabase, Vercel, GitHub y producción. No contiene credenciales, tokens, IP, documentos ni datos personales. No es una certificación ni sustituye una auditoría ofensiva independiente.

1. Resumen ejecutivo

La aplicación dispone de una defensa por capas adecuada para una producción temprana: HTTPS y cabeceras estrictas, CSP en bloqueo, autenticación Supabase, aislamiento RLS por usuario, APIs con bearer y límites de cuerpo, rate limiting distribuido, webhooks firmados, WAF en observación, alertas administrativas y un despliegue que no mueve el dominio hasta superar CI.

La protección frente a robo de archivos ha mejorado de forma concreta:

- las copias manuales de una cuenta autenticada se cifran antes de descargarse;
- las copias de Google Drive se cifran antes de contactar con Drive;
- cada usuario recibe una clave derivada distinta;
- el archivo usa AES-256-GCM, IV aleatorio de 96 bits y metadata autenticada;
- las copias antiguas en JSON siguen siendo importables;
- si el servicio de claves falla, una cuenta iniciada no cae silenciosamente a una copia en claro;
- existe cierre de sesión con borrado local, pero solo después de confirmar la sincronización en la nube.

El registro, la demo y la primera factura no añaden pasos nuevos. Los controles adicionales actúan principalmente en segundo plano. La mayor exposición que permanece es que los datos de trabajo viven en **localStorage** y en payloads JSONB de Supabase sin cifrado de campos a nivel de aplicación. RLS protege a un usuario de otro, pero no convierte esos payloads en datos ilegibles para una service role, un operador autorizado o quien obtuviera un volcado lógico y las claves correspondientes.

2. Qué datos existen y dónde

Superficie	Contenido	Protección principal	Límite actual
Navegador	Perfil, clientes, documentos, gastos y ajustes	Origen HTTPS, CSP, aislamiento del navegador	Una XSS activa o un dispositivo desbloqueado puede leerlos
Supabase sync_entities	Entidades sincronizadas por usuario en JSONB	Auth, RLS por user_id, grants mínimos, cifrado del proveedor en reposo	No hay cifrado de campos a nivel de aplicación
Supabase user_backups	Copias privadas asociadas al usuario	RLS por owner y acceso de servidor	Mismo límite frente a service role o compromiso de base
Copia manual autenticada	Exportación portable de la cuenta	AES-256-GCM y clave derivada por usuario	Requiere sesión de la misma cuenta para descifrar
Google Drive	Hasta diez copias de la app	Cifrado previo en navegador y permiso drive.file	La disponibilidad depende de Google y del acceso a la cuenta Factu
Copia de invitado	Exportación sin cuenta	Aviso explícito y descarga local	Permanece en JSON legible
Supabase Backup	Base completa de producción	Backup diario del proveedor	Retención de 7 días; no hay PITR

3. Navegador, transporte y XSS

- Producción se sirve exclusivamente por HTTPS desde Vercel.
- HSTS mantiene HTTPS durante dos años.
- CSP se sirve mediante **Content-Security-Policy**, no solo en report-only.
- **default-src 'self'**, **object-src 'none'**, **base-uri 'self'** y **form-action 'self'** reducen carga e inyección de recursos no autorizados.
- **script-src-attr 'none'** bloquea JavaScript en atributos HTML.
- **frame-ancestors 'none'** y **X-Frame-Options: DENY** evitan clickjacking.
- **X-Content-Type-Options: nosniff**, Referrer Policy y Permissions Policy reducen fuga de contexto y capacidades innecesarias.
- CORS global permite el origen de producción, no *.
- Las APIs privadas usan **Cache-Control: no-store**. El HTML estático puede ser cacheado como shell, pero no incluye los datos privados de la cuenta.
- Las zonas privadas y APIs se marcan para no indexación.
- Los informes CSP pasan por una ruta limitada, saneada y con rate limit.
- Existe un interruptor operativo para volver temporalmente a report-only si una integración legítima quedara bloqueada.

Riesgo residual: CSP aún permite **unsafe-inline** en **script-src** y estilos. Retirarlo exige nonces y pruebas completas de Next.js, Turnstile, Google, Drive y Maps. Además, cualquier XSS que sí lograra ejecutarse tendría impacto alto porque puede leer **localStorage** y actuar con la sesión abierta.

4. Autenticación, sesiones y administración

- Supabase Auth gestiona usuarios, sesiones y confirmación de email.
- El alta e inicio de sesión por email usan Cloudflare Turnstile contra automatización.
- Las cuentas por email pueden recuperar contraseña mediante enlace al email verificado y definir una nueva dentro de la app.
- Las contraseñas nuevas requieren un mínimo de 12 caracteres; no se fuerzan combinaciones artificiales de mayúsculas, números y símbolos.
- Google Auth valida origen y callback antes del intercambio.
- Las APIs sensibles validan bearer mediante **supabase.auth.getUser(token)**.
- Operaciones de mayor riesgo exigen email confirmado.
- El cierre normal conserva los datos locales para continuar sin cuenta.
- **Cerrar y borrar este dispositivo** intenta subir pendientes, confirma nube, cierra sesión y solo entonces elimina datos principales, tokens de Drive, borradores y ajustes locales. Si no confirma la nube, no borra.

Administración

- El acceso admin exige sesión válida y pertenencia a una allowlist de email.
- La allowlist actual es la unión de dos cuentas propietarias fijadas en código y **ADMIN_EMAILS** de servidor. Los valores concretos se revisan en el código, no se duplican en este informe público.
- La service role se utiliza únicamente en rutas de servidor.
- Las APIs admin sin bearer válido responden **401**.

- La interfaz general de alta/recuperación TOTP está desactivada y el acceso admin no exige AAL2. Un factor TOTP que ya exista en Supabase no convierte por sí solo la sesión admin en obligatoriamente multifactor.

Riesgo residual: una contraseña o sesión robada de una cuenta de la allowlist puede abrir Admin. Convertir MFA admin en obligatorio es la mejora de menor fricción para usuarios normales y mayor valor pendiente. La allowlist fijada en código debe tratarse como una decisión explícita de ownership y revisarse en cada cambio de administradores.

5. Supabase, RLS y privilegios

- RLS está habilitado para tablas expuestas con datos por usuario.
- **sync_entities** y **user_backups** filtran lectura, inserción y actualización mediante **auth.uid() = user_id**.
- Billing, Stripe, rate limit, restauraciones admin, aprendizaje IA, errores, fiscalidad, inbox y Partners tienen RLS y/o revocaciones para **public**, **anon** y **authenticated** según su contrato.
- Los RPC sensibles revocan ejecución pública y se conceden solo a roles previstos.
- Las columnas de owner usadas por RLS cuentan con índices donde corresponde.
- La service role no se incluye en variables **NEXT_PUBLIC_** ni se envía al navegador.
- No se observaron buckets públicos de Storage en la revisión de producción.
- Supabase Pro mantiene backups diarios con siete días de retención y siete días de logs.
- Las migraciones viven en Git, pasan convenciones y aceptación local. Algunas migraciones productivas muy acotadas incorporan checksum, advisory lock, transacción y verificación posterior; esto no equivale todavía a un sistema universal de migraciones automáticas para todo el esquema.

Qué cubre RLS: evita que un usuario normal lea o escriba filas de otro a través de las APIs de Supabase. **Qué no cubre:** la service role evita RLS por diseño; un secreto de servidor robado, una ruta admin vulnerable o un acceso de base privilegiado requieren controles adicionales.

6. Cifrado de copias y gestión de claves

Implementación vigente

- Algoritmo: AES-256-GCM mediante Web Crypto.
- IV: 12 bytes aleatorios por operación; no se reutiliza deliberadamente.
- Tag de autenticación: 128 bits.
- Metadata autenticada: formato, versión de sobre, algoritmo, versión de clave y fecha de creación se incluyen como **additionalData**.
- Derivación: HKDF-SHA256 desde una clave maestra de 32 bytes y el UUID del usuario. Dos usuarios no reciben la misma clave derivada.
- Separación: el archivo cifrado queda en el dispositivo o Drive; la clave maestra queda como variable sensible de Vercel, nunca en el archivo ni Git.
- Versionado: **keyVersion** permite crear una clave nueva sin perder acceso a copias antiguas. Las claves históricas no deben borrarse al rotar.
- La API **/api/security/backup-key** exige bearer, no permite caché y aplica rate limit distribuido.
- Google Drive exige cifrado y prepara el sobre antes de hacer la primera petición a Drive.
- La importación reconoce tanto el sobre cifrado como el JSON histórico.

Qué protege

- Un archivo manual o de Drive robado no revela clientes, facturas o gastos sin la cuenta Factu correcta y una versión de clave disponible.
- Una modificación del ciphertext o de la metadata autenticada hace fallar el descifrado.
- Un fallo de configuración no produce una copia autenticada en claro.

Qué no protege

- Una XSS activa o un atacante con la sesión ya abierta puede pedir la clave derivada del mismo usuario y leer los datos que la sesión ya autoriza.
- La clave maestra vive en Vercel Sensitive Environment Variables, no en un KMS/HSM dedicado controlado por la aplicación.
- Un compromiso conjunto de Vercel, sesión/UUID y archivo cifrado puede romper esta separación.
- Los payloads de **sync_entities** no están cifrados a nivel de aplicación.
- Las copias técnicas previas a restauraciones/repares que deben ejecutarse sin ceder el control siguen usando JSON legible para conservar su garantía anti-pérdida. Deben almacenarse con el mismo cuidado que una exportación antigua.
- Un usuario sin cuenta puede exportar JSON legible; la UI lo advierte.

7. APIs, archivos y servicios externos

- Un inventario automatizado clasifica cada API por método, autenticación, firma, rate limit y límites de cuerpo.
- Las rutas JSON, texto y multipart limitan bytes reales aunque falte **Content-Length**.
- El escaneo de gastos valida tipo y tamaño, exige sesión/cuota cuando aplica y limita automatizaciones. Los admins tienen umbrales mayores, no ausencia total de contención.
- Stripe verifica firma sobre el cuerpo exacto, limita payload y usa idempotencia durable.
- Resend/Svix verifica firma o secreto privado y limita payload.
- Google token y Drive validan origen, callback y cuenta.
- Las rutas experimentales de sincronización/ingesta permanecen tras flags y cerradas por defecto.
- Los errores públicos no devuelven stack, token ni secreto interno.
- Las respuestas sensibles usan no-store.

8. Rate limiting, scraping y abuso

- El backend principal de rate limit es Supabase y comparte contadores entre instancias Vercel.
- Los identificadores se hashéan con salt privado; no se almacenan IP ni email en claro en esos buckets.
- Existe fallback en memoria para degradación controlada.
- Vercel Firewall y System Mitigations/DDoS están activos.
- Bot Protection y AI Bots observan en modo **Log** para no añadir fricción.
- Attack Mode permanece apagado.
- No hay deny/challenge global ni bloqueos IP sin evidencia.
- Un workflow revisa señales cada 15 minutos y envía email ante alerta roja reciente; deduplica avisos iguales durante seis horas.
- Admin agrega actividad de escaneo, APIs, exportaciones, Drive, pulls cloud, CSP, Vercel y errores. Los logs copiables omiten tokens, IP, documentos y payloads.

- Las exportaciones y pulls registran contadores de elementos/bytes, no el contenido. Una exportación grande puede marcar la sección Seguridad.

El scraping no puede eliminarse al 100 %. Las zonas privadas, RLS, cuotas, límites, WAF y alertas reducen abuso. Un bot distribuido, lento o que consulte Supabase directamente puede evitar parte de la telemetría de interfaz; los logs son señal de detección, no prueba forense completa.

9. Backups, restauración e integridad

- Supabase Pro ofrece backup diario y acceso a los siete últimos días.
- PITR no está contratado. Una restauración global diaria puede perder cambios posteriores al punto seleccionado y afecta a todos los usuarios.
- Los backups de base no restauran objetos eliminados de Supabase Storage; hoy no se depende de buckets públicos para los documentos del usuario.
- La restauración desde Cuenta exige selección, parseo, límites, vista previa y confirmación antes de aplicar.
- La copia previa protege frente a una restauración equivocada.
- Documentos emitidos, snapshots, hashes, relaciones, numeración y registros fiscales tienen invariantes y pruebas específicas.
- La restauración administrativa por usuario permite listar/crear puntos, pero el apply permanece bloqueado fail-closed hasta existir una operación transaccional o saga reanudable con CAS, rollback y evidencia indivisible.

10. Admin y observabilidad para una persona no técnica

Admin separa Usuarios, Seguridad, Supabase, Vercel, Errores, IA y operaciones. Una sección pasa a ámbar o rojo cuando necesita atención y conserva el aviso hasta abrirla. Cada zona puede generar un log copiable con:

- estado y señales saneadas;
- contexto del proyecto para Codex;
- repositorio y URL de producción;
- reglas de trabajo seguro;
- flujo obligatorio de Git y verificación de Production Domain.

Ante un aviso rojo:

1. Abrir la sección y pulsar Actualizar.
2. Leer el resumen visual.
3. Copiar el log completo y pegarlo en Codex.
4. No añadir contraseñas, tokens, PDFs ni datos de clientes.
5. No activar bloqueos globales ni tocar datos reales a ciegas.
6. Aplicar correcciones por rama, PR, checks, **main** y Production Domain.

11. Git, dependencias y despliegue

- Todo cambio de código, configuración documentada o informe pasa por Git.
- Flujo: rama -> commit -> push -> PR -> checks -> merge -> CI de **main** -> Production Domain -> verificación externa.
- Quality ejecuta convenciones de migración, tests, lint, TypeScript y build.
- Supabase Acceptance levanta una base local y prueba contratos de producción.

- CodeQL analiza Actions, JavaScript, TypeScript y Python.
- Dependabot, secret scanning y push protection están activos.
- Vercel Preview valida cada PR.
- Un push a **main** espera el deployment, asigna explícitamente **facturacion-autonomos.app** y verifica el dominio.
- Admin compara SHA de GitHub, CI, deployment Vercel y alias para detectar una producción antigua.

12. Matriz de ataques y cobertura actual

Vector	Cobertura actual	Riesgo residual
IDOR / acceso entre usuarios	RLS owner, bearer server y pruebas de aislamiento	Error futuro en una policy o uso indebido de service role
Credential stuffing	Turnstile, límites Auth, contraseña mínima y logs	Contraseña reutilizada; leaked-password protection debe comprobarse en Dashboard
XSS	CSP enforce, script-src-attr none , React y límites de contenido	unsafe-inline y alto impacto por localStorage
CSRF	APIs sensibles con bearer, callbacks/orígenes validados	Revisar cada nueva ruta que use cookies automáticas
SQL/command injection	Supabase SDK, consultas parametrizadas y payloads validados	RPC/SQL dinámico nuevo requiere revisión específica
Webhook spoof/replay	Firmas Stripe/Svix, payload exacto e idempotencia	Secreto robado o lógica de negocio incorrecta
Upload/ZIP/PDF bomb	Tipo/tamaño, body limits y parser controlado	Parsers de terceros y consumo de memoria dentro del límite
Scraping/bots	WAF log, rate limit, cuotas, robots y alertas	Bots distribuidos y contenido público inevitablemente copiable
Exfiltración por exportación	Telemetría, alerta visual y archivos cifrados	Sesión legítima comprometida o exportación técnica antigua
Robo de backup	AES-GCM por usuario y clave separada del archivo	Compromiso combinado de sesión/Vercel o claves históricas
Robo de base	RLS, grants, cifrado del proveedor en reposo	Volcado lógico/service role ve JSONB sin cifrado de aplicación
DDoS / coste	Vercel mitigations, límites distribuidos y cuotas	Ataque volumétrico avanzado o gasto de servicios externos
Supply chain	lockfile, npm ci , CodeQL, Dependabot y CI	Vulnerabilidad 0-day o paquete legítimo comprometido
Clickjacking	frame-ancestors none y DENY	Muy bajo mientras se mantengan cabeceras

13. Fricción para el usuario

Flujo	Impacto visible
Demo y primera factura	Ninguno añadido
Registro/login	Turnstile cuando corresponde y confirmación de email
Uso diario	Sin pasos nuevos
Copia manual con cuenta	Breve espera mientras cifra; archivo no legible directamente
Copia Drive	Mismo botón/automatismo; el cifrado es previo y transparente
Restaurar copia cifrada	Requiere iniciar sesión con la cuenta que la creó
Dispositivo compartido	Opción explícita de cerrar y borrar tras sincronizar
Admin	Sin MFA obligatorio a día de hoy

14. Riesgos pendientes priorizados

Prioridad alta

1. **XSS con impacto en datos locales.** Mantener CSP y revisar cualquier HTML, markdown, PDF o texto que llegue a renderizado. Planificar nonces para retirar **unsafe-inline** sin romper integraciones.
2. **MFA admin no obligatorio.** Exigir AAL2 solo a la allowlist admin; no añade fricción a usuarios normales.
3. **Payload cloud sin cifrado de aplicación.** Diseñar una fase separada con versionado, rotación, recuperación, búsqueda y migración reversible. No aplicar un cifrado masivo directamente sobre datos reales.

Prioridad media

4. Migrar la clave maestra de backup a KMS/HSM si el volumen o la obligación contractual lo justifica.
5. Cifrar también copias técnicas pre-restauración sin romper la garantía de commit atómico del navegador.
6. Confirmar **Leaked password protection** en Supabase Dashboard.
7. Mantener revisión mensual de Security Advisor, Performance Advisor, Auth, RLS, buckets y logs.
8. Contratar PITR cuando el coste de perder hasta 24 horas supere el coste del add-on y del compute requerido.

Prioridad condicionada a evidencia

9. Pasar Bot Protection de **Log** a challenge/deny solo tras medir falsos positivos y rutas afectadas.
10. Añadir Storage backup independiente si se empiezan a guardar objetos reales en Supabase Storage.

15. Verificación vigente

Comprobaciones realizadas el 17 de julio de 2026:

- **/cuenta** responde **200** en producción.
- CSP se sirve en modo bloqueo; CORS queda limitado al dominio de producción.
- HSTS, **nosniff**, **DENY**, Referrer Policy y Permissions Policy están presentes.
- **/api/security/backup-key** sin sesión responde **401** y **no-store**.
- Una cuenta autenticada generó una copia real con formato externo **factu-encrypted-backup**, AES-GCM, versión de clave e IV de 12 bytes; el sobre no contenía marcadores JSON de perfil o documentos.
- Quality, Supabase Acceptance, CodeQL y Production Domain pasaron en **main**.
- El dominio quedó asignado al deployment del merge verificado.
- La suite local completa de la fase de cifrado superó 8.459 pruebas, lint, TypeScript y build de 344 rutas.
- **npm audit** de la instalación verificada no reportó vulnerabilidades conocidas.

16. Referencias técnicas

- OWASP Cryptographic Storage Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html
- MDN AesGcmParams: <https://developer.mozilla.org/en-US/docs/Web/API/AesGcmParams>
- Supabase Row Level Security: <https://supabase.com/docs/guides/database/postgres/row-level-security>
- Supabase Database Backups: <https://supabase.com/docs/guides/platform/backups>
- Vercel Sensitive Environment Variables: <https://vercel.com/docs/environment-variables/sensitive-environment-variables>

17. Documentos operativos relacionados

- **docs/operacion/blindaje-datos-usuarios.md**: invariantes de integridad y recuperación, no otra fotografía general de seguridad.
- **docs/operacion/supabase-security-checklist.md**: revisión mensual.
- **docs/VERCEL_PRODUCION.md**: secretos, despliegue, dominio y rotación.
- **AUDITORIA_FACTURA_AUTONOMO.md**: auditoría histórica del producto; no usar como estado actual.